

SOP-SK-03 — Compliance Assessment (UU PDP / GDPR / PCI-DSS)

Kode	SOP-SK-03
Pemilik	Senku (Governance/Compliance Specialist)
Revisi	1.0 · Berlaku 2026-05-29 · Reviu per kuartal
Referensi	UU PDP (UU 27/2022), GDPR (EU 2016/679), PCI-DSS, ISO/IEC 27001, tools/compliance-checklist-pdp.md
COBIT	MEA03 (Managed Compliance with External Requirements — Owner)

1. Tujuan

Memastikan **tidak ada fitur yang menyentuh data pribadi atau pembayaran rilis tanpa lolos penilaian kepatuhan** regulasi eksternal yang berlaku. Ini kontrol internal SK-C3 dan inti peran MEA03 Senku.

2. Ruang Lingkup

- **Berlaku:** semua fitur/integrasi yang **collect, store, process, atau transfer data pribadi (PII)** atau **data pembayaran**.
- **Tidak berlaku:** fitur murni statis tanpa data pribadi (cth: landing page marketing yang gak collect data).

3. Definisi & Istilah

- **PII** — Personally Identifiable Information: nama, email, no HP, NIK, alamat, data lokasi.
- **Consent eksplisit** — persetujuan aktif pemilik data sebelum diproses (UU PDP & GDPR wajib).
- **Breach notification** — kewajiban lapor kebocoran (UU PDP: tanpa tunda wajar ke pemilik + otoritas; GDPR: 72 jam).
- **DPIA** — Data Protection Impact Assessment untuk pemrosesan berisiko tinggi.
- **SAQ** — Self-Assessment Questionnaire PCI-DSS (SAQ-A paling ringan, kalau gateway tersertifikasi yang handle kartu).
- **Data classification** — Public / Internal / PII / Sensitive PII.

4. Referensi

UU PDP (UU 27/2022) — primary untuk produk Indo; GDPR (kalau user EU); PCI-DSS (kalau payment); ISO/IEC 27001 Annex A (kalau enterprise); Tata mandate Data SACRED (audit trail who/when/what/why, no hard delete).

5. Tanggung Jawab (RACI)

Aktivitas	R	A	C	I
Compliance assessment	Senku	Senku	@saitama (BE control), @shikamaru (data)	Tata
Desain kontrol mitigasi	@saitama / @shikamaru	Senku	@kakashi	Tata
Escalation red-flag	Senku (lapor)	Tata	@kakashi	tim
Keputusan terima risiko residual	—	Tata	Senku, Kakashi	tim

6. Prosedur

6.1 Scoping

- 6.1.1 Petakan **data yang disentuh + classification** (Public/Internal/PII/Sensitive PII) + **lineage** (origin → transform → storage → consume).
- 6.1.2 Tentukan **regulasi applicable** ([tabel PLAYBOOK §1.4]): produk Indo proses PII → **UU PDP**; user EU → GDPR; payment → PCI-DSS; enterprise → ISO 27001.
- 6.1.3 **Exit kalau gak ada PII/payment** → assessment N/A, catat alasan, selesai.

6.2 Penilaian per regulasi

- 6.2.1 **UU PDP (UU 27/2022)** — cek via [compliance-checklist-pdp](#):
 - a. Consent eksplisit untuk tiap PII processing?
 - b. Hak subjek data (akses, koreksi, hapus) tersedia?
 - c. Breach notification mechanism ada?
 - d. DPO requirement (kalau scale besar / data sensitif sistematis)?
 - e. Cross-border transfer assessment (kalau infra/vendor di luar Indo)?
 - f. Retention policy jelas + soft delete (Data SACRED)?
- 6.2.2 **GDPR** (kalau user EU): consent, DPO, breach 72 jam, DPIA high-risk.
- 6.2.3 **PCI-DSS** (kalau payment): scope SAQ; **jangan simpan PAN/CVV**; pakai gateway tersertifikasi (Stripe/Midtrans handle most).
- 6.2.4 **ISO 27001** (kalau enterprise): Annex A control relevan + risk treatment.

6.3 Risk & audit trail

- 6.3.1 Susun **risk assessment** (likelihood × impact + mitigation per risk).
- 6.3.2 Verifikasi **audit trail design** comply Data SACRED: who (user_id+role) · when (timestamp UTC) · what (action+resource+before/after) · why (context). No hard delete (kontrol SK-C6).
- 6.3.3 **Decision point — severity** (PLAYBOOK §5.6):
 -  **Critical** (PII tanpa consent / payment tanpa PCI scope) → **escalate ≤ 1 hari kerja** (kontrol SK-C4), **block adopsi** sampai mitigasi.
 -  **Major** (cross-border / retention unclear) → flag Tata + Kakashi, butuh keputusan.
 -  **Minor** (dokumentasi kurang) → catat, fix sebelum live.

6.4 Output

- 6.4.1 Tulis **compliance report**: scope, regulasi applicable, checklist hasil, risk + mitigation, verdict (compliant / compliant-with-constraint / non-compliant).
- 6.4.2 **Exit criteria**: semua regulasi applicable ter-cek + risk ada mitigation + red-flag (kalau ada) ter-escalate + audit trail design verified.

7. Pengecualian

- **Tidak ada bypass** untuk fitur sentuh PII/payment. **Compliance = hard gate**. Tata boleh terima **risiko residual** secara eksplisit (tercatat), tapi gak boleh diam-diam skip assessment.

8. Rekaman & Retensi

Rekaman	Lokasi	Retensi
Compliance report	log.md (+ adr/ kalau Type-1)	Permanen
Risk assessment + mitigation	log.md	Permanen
Escalation red-flag	log.md + ACTIVITY	Permanen
Keputusan terima risiko residual (Tata)	log.md	Permanen

9. Indikator Kinerja (KPI)

KPI	Rumus	Target
Compliance coverage	# fitur data/payment ber-assessment ÷ total	100%
Red-flag latency	jam temuan → escalate	< 1 hari kerja
Non-compliant ke produksi	# fitur live ketahuan non-compliant	0

10. Riwayat Revisi

Rev	Tanggal	Perubahan
1.0	2026-05-29	Terbit pertama. Contoh acuan: payment (PCI scope), /daftar consent flow (UU PDP)